QUANTUM SECURITY INTELLIGENCE

Отчёт об аудите безопасности и постквантовой готовности

lightwalletd @ 4abfe9cd7b9b · Electric Coin Company (Zcash) — публичный репозиторий (пассивная проверка)

Организация	QSI
Дата отчёта	2026-11-06 13:26 UTC
Версия отчёта	1
Запуск аудита	6439c054-7e30-4b13-88fc-4e7ce112dd4f · Документальный аудит · 2026-11-06 13:26 UTC
Версия анализатора	qsi-engine 1.3.0
Профиль риска	Криптобиржа, кастодиан или кошелёк
SHA-256 содержимого	`9504d578ac265b51de4004dce82ba857ca6f01624df2bbbf459dc504ecb818c6`
Ключ подписи (Ed25519, отпечаток SHA-256; подпись — отдельный файл report.sig.json)	`5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`

Содержание

1. Резюме для руководства
2. Область и границы проверки
3. Методология
4. Проверенные и непроверенные активы
5. Краткое описание архитектуры
6. Общая оценка состояния безопасности
7. Сводка находок по серьёзности
8. Подробное описание находок
9. Подтверждающие доказательства
10. Постквантовая оценка
11. Ограничения и допущения
12. План устранения проблем
13. Приоритеты на 30, 60 и 90 дней
14. Проверки после устранения
15. Использованные инструменты
16. Источники и нормативные документы
17. Приложения

Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.

Резюме для руководства

13	0	0	2	1
Всего находок	Критическая	Высокая	Средняя	Низкая

Классификация	Количество
Подтверждённая техническая уязвимость	1
Известная уязвимая версия компонента	10
Подтверждённая ошибка конфигурации	0
Потенциальный криптографический риск	0
Долгосрочный постквантовый риск	2
Рекомендация по улучшению	0
Недостаточность данных	0

Top 5

ID	Серьёзность	Подробное описание находок	Балл приоритета
QSI-2026-18277	Средняя	Квантово-уязвимый ключ RSA в сертификате (lightwalletd.testnet.local)	50.3
QSI-2026-18275	Средняя	Квантово-уязвимый RSA: роль не определена (1 файл(ов)) предварительно	34.2
QSI-2026-18278	Низкая	golang.org/x/crypto v0.55.0 затронут GO-2026-5932 (без оценки серьёзности) предварительно	20.3
QSI-2026-18276	Информационная	Закрытый ключ присутствует в docker/cert.key не применимо к этому коду	58.0
QSI-2026-18279	Информационная	golang.org/x/crypto v0.55.0 затронут GO-2026-6354 (CVE-2026-78662) (без оценки серьёзности) предварительно	17.8

Неравенство Моски (x + y > z): x = 10, y = 5, z = 8 → при этом сценарии миграция завершится слишком поздно. z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Проверка аналитика: подтверждено — 0, не применимо — 1, отклонено как ложные срабатывания — 0.

Постквантовая зрелость: Уровень 4 из 4 — постквантовое по умолчанию в критичных путях. Следующий шаг: Поддерживайте инвентарь в актуальном состоянии и проверяйте новые пути кода перед выпуском.

Область и границы проверки

Режим: Документальный аудит

Репозиторий: https://github.com/zcash/lightwalletd @ 4abfe9cd7b9b13f6093df59911639d1d9195dc09 — ссылки в доказательствах открывают строки на этом коммите.

Предоставленные входные данные

34 файлов, всего 458533 байт, редактирований: 1; список SHA-256 по файлам — в приложении C.

Методология

Аудит выполнен движком QSI 1.3.0. Каждый анализатор формирует факты (правило, параметры, доказательства); тексты находок генерируются из каталога правил. Источники методики указаны в разделе «Источники и нормативные документы».

Приоритизация: объяснимая взвешенная модель (серьёзность, вероятность эксплуатации, доступность атакующему, влияние на конфиденциальность/целостность/доступность с весами профиля «Криптобиржа, кастодиан или кошелёк», критичность актива, срочность, простота устранения) с множителем уверенности. CVSS v3.1 применяется только к техническим уязвимостям с определённым вектором. Для долгосрочных квантовых рисков используется неравенство Моски; их серьёзность ограничена уровнем «Средняя», и они никогда не представляются как эксплуатируемые уязвимости.

Классификация находок: подтверждённая техническая уязвимость; известная уязвимая версия компонента (версия зависимости названа в бюллетене; затронутый код может не вызываться — это проверяется отдельно, а подтверждённая проверкой становится уязвимостью); подтверждённая ошибка конфигурации; потенциальный криптографический риск; долгосрочный постквантовый риск; рекомендация по улучшению; недостаточность данных. Находки на основе эвристик помечены как предварительные; решения аналитика показаны рядом с находками.

Покрытие проверок

Область	Статус	Количество	Примеры
source_code	проверено	28	cmd/connstats.go: 39 lines scanned with 16 rule patterns and 266 registry patterns; cmd/root.go: 535 lines scanned with 16 rule patterns and 266 registry patterns; cmd/version.go: 22 lines scanned with 16 rule patterns and 266 registry patterns
tls_code	проверено	2	common/generatecerts.go: TLS key-exchange settings read; frontend/rawrequest.go: TLS key-exchange settings read
certificates_and_keys	проверено	2	docker/cert.key: certificates/keys parsed; docker/cert.pem: certificates/keys parsed
dependencies	проверено	1	go.mod: 48 dependencies parsed (48 pinned)
entropy	проверено	1	random-number generation: 28 code files read with 0 macro definitions from the tree; 0 ineffective guard(s), 0 weak random-bytes provider(s), 0 weak key-generation site(s)
osv_advisories	проверено	1	48 pinned packages queried at OSV.dev; 2 affected

Длинные списки здесь сгруппированы; полный список по файлам — в JSON-версии отчёта, подписанной тем же ключом.

Проверенные и непроверенные активы

Предоставленные входные данные: 33 (входные файлы: C)

Краткое описание архитектуры

Static review of the source tree lightwalletd at 4abfe9cd7b9b13f6093df59911639d1d9195dc09. 34 files analysed; of 121 files, 24 are test, fuzzing, benchmark or example code and were left out, 63 are not read by any analyzer, 0 exceed the per-file limit and 0 did not fit the total limit. Files no analyzer reads include: .codecov.yml, .env.template, .github/ISSUE_TEMPLATE/bug-report.md, .github/ISSUE_TEMPLATE/feature-request.md, .github/pull_request_template.md. 46 files in build-output or dependency-cache directories (.git, .hg, .venv, __pycache__, build, dist, node_modules, target, vendor, venv) were not read. No requests were sent to the owner's systems.

Общая оценка состояния безопасности

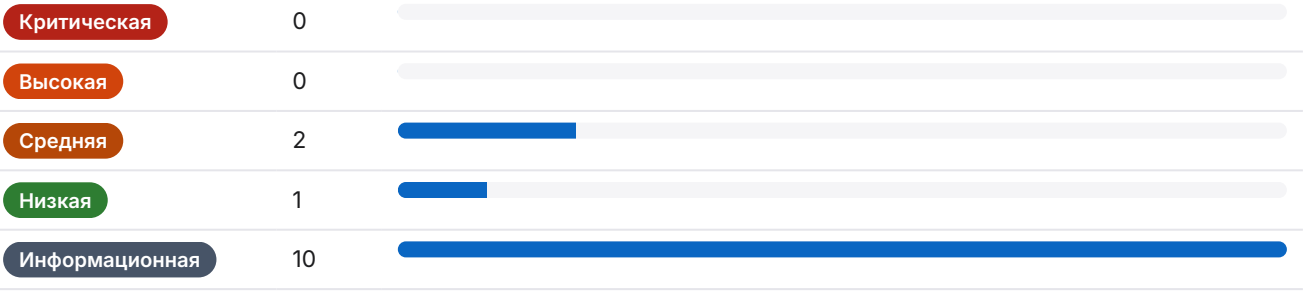
99
Ориентировочный индекс состояния (0–100)

33.3%
Доля квантово-уязвимых элементов инвентаризации

9
Криптографическая инвентаризация

Рассчитан по находкам в области проверки (подтверждённые и потенциальные проблемы, взвешенные по серьёзности). Ориентировочный; не сравним между аудитами с разной областью.

Сводка находок по серьёзности



ID	Подробное описание находок	Классификация	Серьёзность	Уверенность
QSI-2026-18277	Квантово-уязвимый ключ RSA в сертификате (lightwalletd.testnet.local)	Долгосрочный постквантовый риск	Средняя	Высокая
QSI-2026-18275	Квантово-уязвимый RSA: роль не определена (1 файл(ов))	Долгосрочный постквантовый риск	Средняя	Средняя, предварительно
QSI-2026-18278	golang.org/x/crypto v0.55.0 затронут GO-2026-5932 (без оценки серьёзности)	Известная уязвимая версия компонента	Низкая	Низкая, предварительно
QSI-2026-18276	Закрытый ключ присутствует в docker/cert.key	Подтверждённая техническая уязвимость	Информационная	Высокая
QSI-2026-18279	golang.org/x/crypto v0.55.0 затронут GO-2026-6354 (CVE-2026-78662) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно
QSI-2026-18280	golang.org/x/crypto v0.55.0 затронут GO-2026-6355 (CVE-2026-56855) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно
QSI-2026-18281	golang.org/x/net v0.58.0 затронут GO-2026-6603 (CVE-2026-78659) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно
QSI-2026-18282	golang.org/x/net v0.58.0 затронут GO-2026-6610 (CVE-2026-78660) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно
QSI-2026-18283	golang.org/x/net v0.58.0 затронут GO-2026-6611 (CVE-2026-78669) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно

QSI-2026-18284	golang.org/x/net v0.58.0 затронут GO-2026-6612 (CVE-2026-78663) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно
QSI-2026-18285	golang.org/x/net v0.58.0 затронут GO-2026-6617 (CVE-2026-97032) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно
QSI-2026-18286	golang.org/x/net v0.58.0 затронут GO-2026-6860 (CVE-2026-78661) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно
QSI-2026-18287	golang.org/x/net v0.58.0 затронут GO-2026-6866 (CVE-2026-97045) (без оценки серьёзности)	Известная уязвимая версия компонента	Информационная	Низкая, предварительно

Подробное описание находок

QSI-2026-18277 · CERT-QV-KEY

Средняя

Квантово-уязвимый ключ RSA в сертификате (lightwalletd.testnet.local)

Долгосрочный постквантовый риск | Уверенность: Высокая

Сертификат lightwalletd.testnet.local использует открытый ключ RSA 2048-bit, действителен до 2029-12-15. RSA взламывается алгоритмом Шора на CRQC.

Затронутый актив	certificate:lightwalletd.testnet.local
Источник данных	docker/cert.pem
Метод обнаружения	Определение алгоритма открытого ключа X.509.
Анализатор	certificates 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	50.3 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=3.11, y=5.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Для аутентификации риск реализуется только если CRQC появится, пока ключ/сертификат ещё доверенный. Сертификаты короткоживущие, поэтому основной вопрос — PKI и долгоживущие корневые/промежуточные сертификаты.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
openssl x509 -in docker/cert.pem -noout -text | grep -A2 'Public Key Algorithm'
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

certificate · docker/cert.pem · line 1 · SHA-256 4cd9b3240260015c... · Файл 8d44580bca050fd5...

```
Subject: CN=lightwalletd.testnet.local,O=MyOrg\, Inc.,ST=CA,C=US
Issuer: CN=lightwalletd.testnet.local,O=MyOrg\, Inc.,ST=CA,C=US
Serial: 7af3c04cf3fbe2a63724f13ab376b1c670bcaf1c
Not before: 2019-12-18T14:24:54+00:00
Not after: 2029-12-15T14:24:54+00:00
Public key: RSA 2048-bit
Signature algorithm: 1.2.840.113549.1.1.11
Signature hash: sha256
CA: True
SAN: -
SHA-256 fingerprint: 907548fce41ead924e1a866da5bb154a58b5b7e503443babd2da3e6d597341c4
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня.

РЕКОМЕНДАЦИЯ

Учитывайте в PQC-инвентаризации; используйте короткие сроки действия; следуйте рекомендациям CA/Browser Forum и NIST по переходу на сертификаты ML-DSA.

ПОВТОРНАЯ ПРОВЕРКА

Повторите аудит после внедрения PQC или гибридных сертификатов.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-18275 · CODE-QV-ASYMMETRIC

Средняя

Квантово-уязвимый RSA: роль не определена (1 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

2 упоминаний RSA в 1 файл(ах), например common/generatecerts.go:8. Роль по путям, именам функций и соседнему коду: роль не определена. По коду не видно, что защищают ключи; приоритет определит проверка.

Затронутый актив	source-code:RSA:general
Источник данных	common/generatecerts.go
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	34.2 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=10.0, y=5.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте common/generatecerts.go:8 и проверьте приведённые строки; остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · common/generatecerts.go · line 8 · SHA-256 9b1ce2f208b801d0… · Файл 010d1a90f0fea3ba…

```
  7 | "crypto/rand"
  8 | "crypto/rsa"
  9 | "crypto/tls"
```

file_excerpt · common/generatecerts.go · line 21 · SHA-256 7bc59a5974adbfd5… · Файл 010d1a90f0fea3ba…

```
 20 |
 21 | privKey, err := rsa.GenerateKey(rand.Reader, 2048)
 22 | if err != nil {
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-18278 · DEP-ADVISORY-UNRATED

Низкая

golang.org/x/crypto v0.55.0 затронут GO-2026-5932 (без оценки серьёзности)

Известная уязвимая версия компонента | Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-5932 для пакета Go golang.org/x/crypto версии v0.55.0: The golang.org/x/crypto/openpgp package is unmaintained, unsafe by design, and has known security issues. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Бюллетень не называет затронутых функций, поэтому достижимость не определена.

Затронутый актив	dependency:Go/golang.org/x/crypto@v0.55.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	20.3 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-5932
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-5932 · line 53 · SHA-256 79b7a13fb7767fba…


```
{"id": "GO-2026-5932", "aliases": [], "modified": "2026-11-02T22:15:06.677088389Z", "summary": "The golang.org/x/crypto/openpgp package is unmaintained, unsafe by design, and has known security issues", "severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие

зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.58.1-0.20261009181718-2f1f834330b2).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-5932

QSI-2026-18276 · KEY-PRIVATE-IN-INPUT

Информационная

Закрытый ключ присутствует в docker/cert.key

Подтверждённая техническая уязвимость | Уверенность: Высокая

> **Проверка аналитика (QSI review, 2026-10-23): не применимо к этому коду.** Self-signed development certificate generated by gen_cert.sh beside it: CN=lightwalletd.testnet.local with subjectAltName covering only localhost and 127.0.0.1. The key really is committed, so the rule is right, but it authenticates no real domain and is not a production credential. Hygiene for the maintainers rather than a vulnerability; deleting it and relying on gen_cert.sh would close it.
>
> автоматическая серьёзность: Высокая.

Блок «PRIVATE KEY» найден в строке 1 файла docker/cert.key. QSI замаскировал ключ перед сохранением; исходный файл по-прежнему его содержит.

Затронутый актив	file:docker/cert.key
Источник данных	docker/cert.key
Метод обнаружения	Обнаружение PEM-заголовков.
Анализатор	certificates 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	58.0 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	8.1 — CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Любой, кто имеет доступ к файлу (репозиторий, резервные копии, журналы CI), может выдать себя за владельца ключа или расшифровать данные.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
grep -n 'PRIVATE KEY-----' docker/cert.key
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · docker/cert.key · line 1 · SHA-256 8ff5675e3f073e63… · Файл 4d417087d1f50763…

```
Line 1: -----BEGIN PRIVATE KEY----- … [REDACTED BY QSI] … -----END …
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

QSI не может определить, используется ли ключ в продуктиве. Значение ключа не сохранялось.

РЕКОМЕНДАЦИЯ

Считайте ключ скомпрометированным: замените его, отзовите связанные сертификаты, удалите из истории версий, храните ключи в менеджере секретов/HSM.

ПОВТОРНАЯ ПРОВЕРКА

Найдите заголовки закрытых ключей в репозитории и его истории; убедитесь, что старый ключ отозван.

OWASP Application Security Verification Standard

QSI-2026-18279 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/crypto v0.55.0 затронут GO-2026-6354 (CVE-2026-78662) (без оценки серьёзности)

Известная уязвимая версия компонента | Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6354 (CVE-2026-78662) для пакета Go golang.org/x/crypto версии v0.55.0: Prevent DoS on deadlocked undecided channel in golang.org/x/crypto/ssh. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/crypto/ssh.Dial, golang.org/x/crypto/ssh.NewClientConn, golang.org/x/crypto/ssh.NewControlClientConn, golang.org/x/crypto/ssh.NewServerConn, golang.org/x/crypto/ssh.channel.Accept, golang.org/x/crypto/ssh.channel.handlePacket …) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/crypto@v0.55.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6354
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6354 · line 53 · SHA-256 fb187877ccc7bca3…


```
{"id": "GO-2026-6354", "aliases": ["CVE-2026-78662"], "modified": "2026-09-03T10:10:55.147673102Z",
"summary": "Prevent DoS on deadlocked undecided channel in golang.org/x/crypto/ssh", "severity":
null, "declared_in_manifest": true}
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.56.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6354

QSI-2026-18280 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/crypto v0.55.0 затронут GO-2026-6355 (CVE-2026-56855) (без оценки серьёзности)

Известная уязвимая версия компонента | Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6355 (CVE-2026-56855) для пакета Go golang.org/x/crypto версии v0.55.0: Prevent DoS on deadlocked established channel in golang.org/x/crypto/ssh. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/crypto/ssh.Dial, golang.org/x/crypto/ssh.NewClientConn, golang.org/x/crypto/ssh.NewControlClientConn, golang.org/x/crypto/ssh.NewServerConn, golang.org/x/crypto/ssh.channel.handlePacket) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/crypto@v0.55.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6355
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6355 · line 53 · SHA-256 4e6adace91e1ca1e...

{"id": "GO-2026-6355", "aliases": ["CVE-2026-56855"], "modified": "2026-09-24T10:41:42.556134596Z", "summary": "Prevent DoS on deadlocked established channel in golang.org/x/crypto/ssh", "severity": null, "declared_in_manifest": true}

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.56.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6355

QSI-2026-18281 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/net v0.58.0 затронут GO-2026-6603 (CVE-2026-78659) (без оценки серьёзности)

Известная уязвимая версия компонента · Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6603 (CVE-2026-78659) для пакета Go golang.org/x/net версии v0.58.0: HTTP/2 server memory exhaustion due to Trailer headers in net/http. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/net/http2.ClientConn.Close, golang.org/x/net/http2.ClientConn.Ping, golang.org/x/net/http2.ClientConn.RoundTrip, golang.org/x/net/http2.ClientConn.Shutdown, golang.org/x/net/http2.ConfigureServer, golang.org/x/net/http2.ConfigureTransport …) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/net@v0.58.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6603
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6603 · line 54 · SHA-256 9e43850e0da48e9d...


```
{"id": "GO-2026-6603", "aliases": ["BIT-golang-2026-78659", "CVE-2026-78659"], "modified":
"2026-10-16T09:55:47.068117441Z", "summary": "HTTP/2 server memory exhaustion due to Trailer headers
in net/http", "severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.60.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6603

QSI-2026-18282 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/net v0.58.0 затронут GO-2026-6610 (CVE-2026-78660) (без оценки серьёзности)

Известная уязвимая версия компонента | Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6610 (CVE-2026-78660) для пакета Go golang.org/x/net версии v0.58.0: HTTP/2 transport accepts malformed framing-related headers in net/http. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/net/http2.Transport.NewClientConn, golang.org/x/net/http2.Transport.RoundTrip, golang.org/x/net/http2.Transport.RoundTripOpt, golang.org/x/net/http2.clientConnPool.GetClientConn, golang.org/x/net/http2.clientConnReadLoop.handleResponse, golang.org/x/net/http2.noDialClientConnPool.GetClientConn …) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/net@v0.58.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6610
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6610 · line 54 · SHA-256 1b823e53f2709379...


```
{"id": "GO-2026-6610", "aliases": ["BIT-golang-2026-78660", "CVE-2026-78660"], "modified":
"2026-10-16T09:56:04.364467528Z", "summary": "HTTP/2 transport accepts malformed framing-related
headers in net/http", "severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.60.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6610

QSI-2026-18283 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/net v0.58.0 затронут GO-2026-6611 (CVE-2026-78669) (без оценки серьёзности)

Известная уязвимая версия компонента | Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6611 (CVE-2026-78669) для пакета Go golang.org/x/net версии v0.58.0: Excessive CPU consumption from repeated initial window changes in net/http. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/net/http2.ClientConn.Close, golang.org/x/net/http2.ClientConn.Ping, golang.org/x/net/http2.ClientConn.RoundTrip, golang.org/x/net/http2.ClientConn.Shutdown, golang.org/x/net/http2.ClientConn.addStreamLocked, golang.org/x/net/http2.ConfigureServer ...) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/net@v0.58.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC

Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6611
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6611 · line 54 · SHA-256 c9b9f78637131224…


```
{"id": "GO-2026-6611", "aliases": ["BIT-golang-2026-78669", "CVE-2026-78669"], "modified":
"2026-10-16T09:55:38.952277866Z", "summary": "Excessive CPU consumption from repeated initial window
changes in net/http", "severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.60.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6611

QSI-2026-18284 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/net v0.58.0 затронут GO-2026-6612 (CVE-2026-78663) (без оценки серьёзности)

Известная уязвимая версия компонента · Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6612 (CVE-2026-78663) для пакета Go golang.org/x/net версии v0.58.0: Double flow control refund on HTTP/2 server streams in net/http. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/net/http2.ClientConn.Close, golang.org/x/net/http2.ClientConn.Ping, golang.org/x/net/http2.ClientConn.RoundTrip, golang.org/x/net/http2.ClientConn.Shutdown, golang.org/x/net/http2.ConfigureServer, golang.org/x/net/http2.ConfigureTransport …) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/net@v0.58.0
Источник данных	OSV.dev

Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6612
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6612 · line 54 · SHA-256 1471910f88c9bbf8…


```
{"id": "GO-2026-6612", "aliases": ["BIT-golang-2026-78663", "CVE-2026-78663"], "modified":
"2026-10-16T09:55:54.129082194Z", "summary": "Double flow control refund on HTTP/2 server streams in
net/http", "severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.60.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6612

QSI-2026-18285 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/net v0.58.0 затронут GO-2026-6617 (CVE-2026-97032) (без оценки серьёзности)

Известная уязвимая версия компонента · Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6617 (CVE-2026-97032) для пакета Go golang.org/x/net версии v0.58.0: HTTP/2 server crash due to HPACK encoder race in net/http. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/net/http2.ClientConn.Close, golang.org/x/net/http2.ClientConn.Ping, golang.org/x/net/http2.ClientConn.RoundTrip, golang.org/x/net/http2.ClientConn.Shutdown, golang.org/x/net/http2.ConfigureServer, golang.org/x/net/http2.ConfigureTransport …) не упоминается в

проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/net@v0.58.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6617
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6617 · line 54 · SHA-256 b948c88d959bc789…


```
{"id": "GO-2026-6617", "aliases": ["BIT-golang-2026-97032", "CVE-2026-97032"], "modified":
"2026-10-16T09:55:57.350751224Z", "summary": "HTTP/2 server crash due to HPACK encoder race in net/
http", "severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.60.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6617

QSI-2026-18286 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/net v0.58.0 затронут GO-2026-6860 (CVE-2026-78661) (без оценки серьёзности)

Известная уязвимая версия компонента · Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6860 (CVE-2026-78661) для пакета Go golang.org/x/net версии v0.58.0: Avoid quadratic complexity when coalescing text nodes in html in golang.org/x/net. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/net/html.Parse, golang.org/x/net/html.ParseFragment, golang.org/x/net/

html.ParseFragmentWithOptions, golang.org/x/net/html.ParseWithOptions, golang.org/x/net/html.parser.addText, golang.org/x/net/html.parser.fosterParent ...) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/net@v0.58.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6860
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6860 · line 54 · SHA-256 1f106c45371219ba...


```
{"id": "GO-2026-6860", "aliases": ["CVE-2026-78661"], "modified": "2026-10-27T21:30:04.890809062Z",
"summary": "Avoid quadratic complexity when coalescing text nodes in html in golang.org/x/net",
"severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.62.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6860

QSI-2026-18287 · DEP-ADVISORY-UNRATED

Информационная

golang.org/x/net v0.58.0 затронут GO-2026-6866 (CVE-2026-97045) (без оценки серьёзности)

Известная уязвимая версия компонента | Уверенность: Низкая

предварительно — требует дополнительной проверки

OSV.dev сообщает GO-2026-6866 (CVE-2026-97045) для пакета Go golang.org/x/net версии v0.58.0: Check all ancestor namespace transitions when rendering raw text in html in golang.org/x/net. У бюллетеня нет ни вектора CVSS, ни оценки базы данных, поэтому QSI ставит низкую

серьёзность и пометку «предварительно» до разбора. Ни одна из затронутых функций (golang.org/x/net/html.Render, golang.org/x/net/html.childTextNodesAreLiteral) не упоминается в проверенном коде: бюллетень не применим, если они не вызываются косвенно (через трейты, макросы, другие зависимости).

Затронутый актив	dependency:Go/golang.org/x/net@v0.58.0
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch для точной объявленной версии.
Анализатор	dependencies 1.3.0 · 2026-11-06 13:26 UTC
Балл приоритета	17.8 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Неизвестно без разбора: прочитайте бюллетень и проверьте, достижим ли затронутый код в вашей сборке.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
curl -s https://api.osv.dev/v1/vulns/GO-2026-6866
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev GO-2026-6866 · line 54 · SHA-256 102267a016bc5eef...


```
{"id": "GO-2026-6866", "aliases": ["CVE-2026-97045"], "modified": "2026-10-27T21:45:08.978077289Z",
"summary": "Check all ancestor namespace transitions when rendering raw text in html in golang.org/
x/net", "severity": null, "declared_in_manifest": true}
```


ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные об уязвимости получены от OSV.dev в зафиксированное время. У бюллетеня нет оценки серьёзности. Достижимость оценивается по именам, а не по графу вызовов: затронутые функции из бюллетеня — по идентификаторам проверенного кода продукта, флаг Cargo, выключенный по умолчанию, — по проверенным манифестам, платформы — по объявленным целям сборки Rust. Косвенные вызовы (через трейты, макросы, другие зависимости) не прослеживаются. Функция Go учитывается только в файле, который называет и её пакет (метод — и его тип); неэкспортируемые функции — только через экспортируемые.

РЕКОМЕНДАЦИЯ

Разберите бюллетень; если он применим, обновите до исправленной версии (0.62.0).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV advisory GO-2026-6866

Подтверждающие доказательства

ID	Тип	Источник данных	SHA-256
QSI-2026-18277	certificate	docker/cert.pem (line 1)	4cd9b3240260015c81d32a7359585aeb0a8fc54aafe812cd312f2fa3b2bc2e7a
QSI-2026-18275	file_excerpt	common/generatecerts.go (line 8)	9b1ce2f208b801d04fec37816b6888e4ae8b469d0344091f5c8a837ee93158f9
QSI-2026-18275	file_excerpt	common/generatecerts.go (line 21)	7bc59a5974adbfd5570196de74190cfdee0b2b136760fe696a10a96bbe4f03d0
QSI-2026-18278	tool_output	OSV.dev GO-2026-5932 (line 53)	79b7a13fb7767fbace049b5199d913b96ffabce881fc497fd2222d40644da151
QSI-2026-18276	file_excerpt	docker/cert.key (line 1)	8ff5675e3f073e63b697c7e9001d2a28e01d7160748521613aeaa91195b89441
QSI-2026-18279	tool_output	OSV.dev GO-2026-6354 (line 53)	fb187877ccc7bca3e1e620fe5ac478176b0bfa60d40289c6b8513c063eaec76c
QSI-2026-18280	tool_output	OSV.dev GO-2026-6355 (line 53)	4e6adace91e1ca1e94bf05a7bfb237f4851e56b8c982501612e1583273e4073e
QSI-2026-18281	tool_output	OSV.dev GO-2026-6603 (line 54)	9e43850e0da48e9d00589cc2bffb372f39ec5e5a280f2f4b04520a91328fd703
QSI-2026-18282	tool_output	OSV.dev GO-2026-6610 (line 54)	1b823e53f27093797b8a7909032006e1f0f818f04118ad593a4641236392faa9
QSI-2026-18283	tool_output	OSV.dev GO-2026-6611 (line 54)	c9b9f78637131224c5d4073e44c47b7cce490fc5526e3d6b0697b43bc85cab2f
QSI-2026-18284	tool_output	OSV.dev GO-2026-6612 (line 54)	1471910f88c9bbf8395a304fd82510f61567373756002de8bcdc3fbe305890cb
QSI-2026-18285	tool_output	OSV.dev GO-2026-6617 (line 54)	b948c88d959bc78948c7e3b7a746ac4da179933798e9735d02870080906cfc96
QSI-2026-18286	tool_output	OSV.dev GO-2026-6860 (line 54)	1f106c45371219bac0158f7ce44e57c439f50f0c32898616d1563f14cadb1b28
QSI-2026-18287	tool_output	OSV.dev GO-2026-6866 (line 54)	102267a016bc5eef7979a90b1ddd2288ff36b09ab6fa040c808e62f3b55c1f42

Постквантовая оценка

	Обмен ключами (x — сколько данные должны оставаться конфиденциальными; «собери сейчас, расшифруй потом»)	Подписи (x — сколько подписи и ключи должны оставаться доверенными)
Срок жизни данных/ключей x	10	10
Время миграции y	5	5
Принятое число лет до CRQC z	8 (early)	8
x + y − z	7 → при этом сценарии миграция завершится слишком поздно	7 → при этом сценарии миграция завершится слишком поздно

Допущения планирования: x для обмена ключами, x для подписей, y — значения по умолчанию профиля риска «Криптобиржа, кастодиан или кошелёк», а не данные клиента; с фактическими сроками клиента вывод может измениться.

Постквантовая зрелость: Уровень 4 из 4 — постквантовое по умолчанию в критичных путях

- Гибрид — обмен ключами в канале (TLS, Noise, рукопожатия): frontend/rawrequest.go (классическая группа + X25519MLKEM768)
- Используется: X25519MLKEM768 — frontend/rawrequest.go

Следующий шаг: Поддерживайте инвентарь в актуальном состоянии и проверяйте новые пути кода перед выпуском.

Уровни: 0 — нет; 1 — есть, но не подключено; 2 — используется вне критичных путей; 3 — гибрид в критичном пути; 4 — постквантовое по умолчанию в критичных путях (корень доверия, обёртка ключей, обмен ключами в канале). Оценка по коду и манифестам.

Что делают квантово-уязвимые алгоритмы

Роль	Алгоритмы (файлы)	ID	Первый шаг
роль не определена	RSA (1)	QSI-2026-18275	Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема; введите уровень абстракции для криптогибкости

Роль определяется по путям файлов, именам функций и коду вокруг совпадений; проверка её подтверждает. Сначала — ключи корня доверия и обёрнутые ключи: их трудно заменить или можно записать уже сегодня.

z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Квантовый статус	Количество
Гровер: допустимо по NIST, ниже рекомендаций ECCG/ANSSI	4
гибрид	1
н/п	1
уязвим (Шор)	3

Подробное описание находок: QSI-2026-18277, QSI-2026-18275

Анкета постквантовой готовности

Анкета готовности для проекта не заполнялась.

Квантовые алгоритмы, значимые для этой инвентаризации

Квантовый алгоритм	Действие	Алгоритмы из инвентаризации (строк)	Что это значит для аудита
Алгоритм Шора — факторизация Q1: квантовые вычисления офлайн, классический доступ к жертве	взламывает	RSA (3)	Взламывает RSA при любой длине ключа: более длинный модуль лишь полиномиально повышает стоимость. Планируйте переход на ML-KEM (или гибрид) для установления ключей и ML-DSA / SLH-DSA для подписей; начинайте с ключей, защищающих данные, которые должны оставаться конфиденциальными годами («собери сейчас — расшифруй потом»), и с долгоживущих подписей.
Алгоритм Шора — дискретный логарифм на эллиптических кривых Q1: квантовые вычисления офлайн, классический доступ к жертве	взламывает	X25519MLKEM768 (1)	Ключи на эллиптических кривых, по оценкам, падут раньше ключей RSA сопоставимой классической стойкости. В блокчейнах первыми под угрозой монеты, чей открытый ключ уже опубликован (повторно используемые адреса, выходы pay-to-public-key и Taproot); планируйте переход на постквантовые подписи и до этого избегайте повторного использования ключей.
Алгоритм Гровера — поиск ключа и прообразов Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	SHA-2 (4)	Не взлом. Ключи 256 бит (AES-256, ChaCha20) сохраняют хороший запас; AES-128 соответствует категории 1 NIST, но некоторые регуляторы требуют 256-битных ключей в квантово-устойчивых системах (см. запись AES-128). Для долгоживущих данных предпочитайте 256-битные ключи; 256-битные хеши для стойкости к прообразам менять не нужно.

Брассар–Хойер–Тапп — поиск коллизий Q1: квантовые вычисления офлайн, классический доступ к жертве	ослабляет (более длинные ключи восстанавливают запас)	SHA-2 (4)	256-битные хеши (SHA-256, SHA3-256) остаются достаточными по стойкости к коллизиям; 160-битные хеши слабы уже классически (коллизии SHA-1 практичны). Где нужны категории NIST 4–5, используйте хеши на 384/512 бит.
Квантовое решетчатое просеивание Q1: квантовые вычисления офлайн, классический доступ к жертве	учтено в стандартных параметрах	X25519MLKEM768 (1)	Для ML-KEM и ML-DSA в стандартных наборах параметров ничего менять не нужно. Заявление 2024 года о полиномиальном квантовом алгоритме для LWE отозвано после обнаружения ошибки (см. заявления).

Действие: взламывает — алгоритм нужно заменить; ослабляет — более длинные ключи или выходы восстанавливают запас; учтено в стандартных параметрах — при стандартных наборах действий не требуется; только при суперпозиционных запросах — к обычному применению неприменимо.

Ограничения и допущения

- Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.
- z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

План устранения проблем

QSI-2026-18276 · P1 · 30 дн. краткосрочное снижение риска

Немедленно отзовите/замените ключ из docker/cert.key и ограничьте доступ к файлу.

Обоснование	Сокращает окно злоупотребления.
Ожидаемый результат	Раскрытый ключ больше не является доверенным.
Сложность	low
Зависимости	Владелец ключа, доступ к УЦ.
Побочные эффекты	Сервисы, использующие ключ, потребуют передеплоя.
Тесты до изменения	Определите все системы, использующие ключ (по отпечатку).
Тесты после изменения	Подтвердите отзыв (CRL/OCSP) и использование нового ключа.
Условие закрытия	Старый ключ отозван, новый развёрнут.

QSI-2026-18276 · P1 · 60 дн. устранение первопричины

Перенесите хранение ключей в менеджер секретов или HSM; добавьте сканирование секретов в CI и pre-commit; очистите историю.

Обоснование	Предотвращает повторение.
Ожидаемый результат	Ключи не попадают в репозиторий.
Сложность	medium
Зависимости	Менеджер секретов.
Побочные эффекты	Переписывание истории затронет клоны.
Тесты до изменения	Запустите сканер секретов по репозиторию.
Тесты после изменения	Сканер не находит закрытых ключей; CI блокирует новые.
Условие закрытия	Сканирование секретов обязательно в CI; ключей в истории нет.

QSI-2026-18278 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-5932; при необходимости обновите golang.org/x/crypto до исправленной версии (0.58.1-0.20261009181718-2f1f834330b2).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-5932 или результат разбора записан.

QSI-2026-18279 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6354 (CVE-2026-78662); при необходимости обновите golang.org/x/crypto до исправленной версии (0.56.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6354 (CVE-2026-78662) или результат разбора записан.

QSI-2026-18280 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6355 (CVE-2026-56855); при необходимости обновите golang.org/x/crypto до исправленной версии (0.56.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6355 (CVE-2026-56855) или результат разбора записан.

QSI-2026-18281 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6603 (CVE-2026-78659); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6603 (CVE-2026-78659) или результат разбора записан.

QSI-2026-18282 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6610 (CVE-2026-78660); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6610 (CVE-2026-78660) или результат разбора записан.

QSI-2026-18283 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6611 (CVE-2026-78669); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6611 (CVE-2026-78669) или результат разбора записан.

QSI-2026-18284 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6612 (CVE-2026-78663); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6612 (CVE-2026-78663) или результат разбора записан.

QSI-2026-18285 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6617 (CVE-2026-97032); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6617 (CVE-2026-97032) или результат разбора записан.

QSI-2026-18286 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6860 (CVE-2026-78661); при необходимости обновите golang.org/x/net до исправленной версии (0.62.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6860 (CVE-2026-78661) или результат разбора записан.

QSI-2026-18287 · P3 · 60 дн. устранение первопричины

Разберите GO-2026-6866 (CVE-2026-97045); при необходимости обновите golang.org/x/net до исправленной версии (0.62.0).

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Возможны изменения API.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование больше не сообщает GO-2026-6866 (CVE-2026-97045) или результат разбора записан.

QSI-2026-18277 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования RSA в certificate:lightwalletd.testnet.local в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-18275 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования RSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-18277 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию RSA на ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.

Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. или гибридной схемы.

QSI-2026-18275 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию RSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема или гибридной схемы.

Приоритеты на 30, 60 и 90 дней

30 дн.

Приоритет	ID	Действие	Тип
P1	QSI-2026-18276	Немедленно отзовите/замените ключ из docker/cert.key и ограничьте доступ к файлу.	краткосрочное снижение риска

60 дн.

Приоритет	ID	Действие	Тип
P1	QSI-2026-18276	Перенесите хранение ключей в менеджер секретов или HSM; добавьте сканирование секретов в CI и pre-commit; очистите историю.	устранение первопричины
P3	QSI-2026-18278	Разберите GO-2026-5932; при необходимости обновите golang.org/x/crypto до исправленной версии (0.58.1-0.20261009181718-2f1f834330b2).	устранение первопричины
P3	QSI-2026-18279	Разберите GO-2026-6354 (CVE-2026-78662); при необходимости обновите golang.org/x/crypto до исправленной версии (0.56.0).	устранение первопричины
P3	QSI-2026-18280	Разберите GO-2026-6355 (CVE-2026-56855); при необходимости обновите golang.org/x/crypto до исправленной версии (0.56.0).	устранение первопричины
P3	QSI-2026-18281	Разберите GO-2026-6603 (CVE-2026-78659); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).	устранение первопричины
P3	QSI-2026-18282	Разберите GO-2026-6610 (CVE-2026-78660); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).	устранение первопричины
P3	QSI-2026-18283	Разберите GO-2026-6611 (CVE-2026-78669); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).	устранение первопричины
P3	QSI-2026-18284	Разберите GO-2026-6612 (CVE-2026-78663); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).	устранение первопричины
P3	QSI-2026-18285	Разберите GO-2026-6617 (CVE-2026-97032); при необходимости обновите golang.org/x/net до исправленной версии (0.60.0).	устранение первопричины
P3	QSI-2026-18286	Разберите GO-2026-6860 (CVE-2026-78661); при необходимости обновите golang.org/x/net до исправленной версии (0.62.0).	устранение первопричины
P3	QSI-2026-18287	Разберите GO-2026-6866 (CVE-2026-97045); при необходимости обновите golang.org/x/net до исправленной версии (0.62.0).	устранение первопричины

90 дн.

Приоритет	ID	Действие	Тип
P3	QSI-2026-18277	Внесите использования RSA в certificate:lightwalletd.testnet.local в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P3	QSI-2026-18275	Внесите использования RSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P4	QSI-2026-18277	Запланируйте миграцию RSA на ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form where the ecosystem supports it. (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины
P4	QSI-2026-18275	Запланируйте миграцию RSA на ML-DSA (FIPS 204) или SLH-DSA (FIPS 205), в гибридной/композитной форме, где это поддерживает экосистема (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины

Проверки после устранения

ID	Повторная проверка
QSI-2026-18277	Повторите аудит после внедрения PQC или гибридных сертификатов.
QSI-2026-18275	Повторите инвентаризацию после рефакторинга.
QSI-2026-18278	Повторите сканирование зависимостей после обновления.
QSI-2026-18276	Найдите заголовки закрытых ключей в репозитории и его истории; убедитесь, что старый ключ отозван.
QSI-2026-18279	Повторите сканирование зависимостей после обновления.
QSI-2026-18280	Повторите сканирование зависимостей после обновления.
QSI-2026-18281	Повторите сканирование зависимостей после обновления.
QSI-2026-18282	Повторите сканирование зависимостей после обновления.
QSI-2026-18283	Повторите сканирование зависимостей после обновления.
QSI-2026-18284	Повторите сканирование зависимостей после обновления.
QSI-2026-18285	Повторите сканирование зависимостей после обновления.
QSI-2026-18286	Повторите сканирование зависимостей после обновления.
QSI-2026-18287	Повторите сканирование зависимостей после обновления.

Использованные инструменты

Tool	Version
blockchain	1.0.0
certificates	1.2.0
chain_map	1.0.0
configs	1.1.0
dependencies	1.3.0
inventory_document	1.1.0
solidity	1.3.0
source_code	1.4.0
tls_code	1.1.0
tls_live	1.0.0
qsi-engine	1.3.0
OSV.dev API	v1

Источники и нормативные документы

Reviewed: 2026-10-13

1. A. Becker, L. Ducas, N. Gama, T. Laarhoven — New directions in nearest neighbor searching with applications to lattice sieving (SODA 2016; IACR ePrint 2015/1128) — IACR ePrint. https://eprint.iacr.org/2015/1128 (peer-reviewed article: classical sieving in 2^{0.292n + o(n)})
2. A. Chailloux, J. Loyer — Lattice sieving via quantum random walks (ASIACRYPT 2021; IACR ePrint 2021/570) — IACR ePrint. https://eprint.iacr.org/2021/570 (peer-reviewed article: 2^{0.2570d + o(d)}, previously 2^{0.2653d + o(d)} (Laarhoven))
3. A. Chailloux, M. Naya-Plasencia, A. Schrottenloher — An Efficient Quantum Collision Search Algorithm and Implications on Symmetric Cryptography (ASIACRYPT 2017; IACR ePrint 2017/847) — IACR ePrint. https://eprint.iacr.org/2017/847 (peer-reviewed article: Õ(2^{2n/5}) time, O(n) qubits, Õ(2^{n/5}) classical memory)
4. C. Chevignard, P.-A. Fouque, A. Schrottenloher — Reducing the Number of Qubits in Quantum Discrete Logarithms on Elliptic Curves (IACR ePrint 2026/280) — IACR ePrint. https://eprint.iacr.org/2026/280 (revision of a EUROCRYPT 2026 paper: 3.12n + o(n) qubits; for n = 256, 1193 qubits and 22 runs of 2^38.98 Toffoli gates)
5. C. Gidney — How to factor 2048 bit RSA integers with less than a million noisy qubits (arXiv:2505.15917) — arXiv. https://arxiv.org/abs/2505.15917 (preprint (2025-05-21): < 1 million noisy qubits, < 1 week, 0.1% gate error, 1 µs surface-code cycle)
6. C. Gidney, M. Ekerå — How to factor 2048 bit RSA integers in 8 hours using 20 million noisy qubits (Quantum 5, 433) — Quantum. https://doi.org/10.22331/q-2021-04-15-433 (peer-reviewed article (2021): 10^-3 gate error, 1 µs cycle, 10 µs reaction time)
7. C. Zalka — Grover's quantum searching algorithm is optimal (Phys. Rev. A 60, 2746, 1999; arXiv:quant-ph/9711070) — APS. https://doi.org/10.1103/PhysRevA.60.2746 (peer-reviewed article: optimal for any success probability; parallel search gains no more than splitting the space)
8. CRYSTALS-Kyber — Algorithm Specifications and Supporting Documentation (round 3, 2021-08-04) — CRYSTALS team. https://pq-crystals.org/kyber/data/kyber-specification-round3-20210804.pdf (NIST round-3 submission: core-SVP cost 2^{0.292β} classical, 2^{0.265β} quantum; Kyber768 166 quantum bits)
9. Common Vulnerability Scoring System v3.1: Specification Document — FIRST. https://www.first.org/cvss/v3.1/specification-document (final)
10. D. J. Bernstein — Cost analysis of hash collisions: Will quantum computers make SHARCS obsolete? (2009) — cr.yp.to. https://cr.yp.to/hash/collisioncost-20090823.pdf (paper dated 2009-08-23)
11. D. Litinski — How to compute a 256-bit elliptic curve private key with only 50 million Toffoli gates (arXiv:2306.08585) — arXiv. https://arxiv.org/abs/2306.08585 (preprint (2023-06-14): 6000 modules × 1152 physical qubits, one key per 10 minutes under its architecture assumptions)
12. FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM) — NIST. https://csrc.nist.gov/pubs/fips/203/final (final (August 2024))
13. FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA) — NIST. https://csrc.nist.gov/pubs/fips/204/final (final (August 2024))
14. FIPS 205 — Stateless Hash-Based Digital Signature Standard (SLH-DSA) — NIST. https://csrc.nist.gov/pubs/fips/205/final (final (August 2024))
15. G. Brassard, P. Høyer, A. Tapp — Quantum Algorithm for the Collision Problem (LATIN '98; arXiv:quant-ph/9705002) — Springer / arXiv. https://arxiv.org/abs/quant-ph/9705002 (peer-reviewed article: collisions of r-to-one functions in O((N/r)^{1/3}) expected evaluations)
16. J. Proos, C. Zalka — Shor's discrete logarithm quantum algorithm for elliptic curves (Quantum Inf. Comput. 3(4), 2003; arXiv:quant-ph/0301141) — Quantum Information & Computation. https://doi.org/10.26421/QIC3.4-3 (peer-reviewed article)
17. L. K. Grover — A fast quantum mechanical algorithm for database search (STOC 1996) — ACM. https://doi.org/10.1145/237814.237866 (peer-reviewed article)
18. M. Amy et al. — Estimating the cost of generic quantum pre-image attacks on SHA-2 and SHA-3 (SAC 2016; arXiv:1603.09383) — Springer / arXiv. https://arxiv.org/abs/1603.09383 (peer-reviewed article: SHA-256 about 2^153.8 surface-code cycles on 2^12.6 logical qubits; SHA3-256 about 2^146.5 cycles on 2^20)
19. M. Cain et al. — Shor's algorithm is possible with as few as 10,000 reconfigurable atomic qubits (arXiv:2603.28627) — arXiv. https://arxiv.org/abs/2603.28627 (preprint (2026-03-30): P-256 in a few days with 26,000 physical neutral-atom qubits; RSA-2048 one to two orders of magnitude longer)
20. M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018) — IEEE. https://doi.org/10.1109/MSP.2018.3761723 (peer-reviewed article; source of the x + y > z migration inequality)

21. M. Roetteler, M. Naehrig, K. Svore, K. Lauter — Quantum resource estimates for computing elliptic curve discrete logarithms (ASIACRYPT 2017) — IACR / arXiv. https://arxiv.org/abs/1706.06752 (peer-reviewed article: at most 9n + 2⌈log2 n⌉ + 10 qubits and 448 n^3 log2 n + 4090 n^3 Toffoli gates)
22. NIST IR 8547 — Transition to Post-Quantum Cryptography Standards — NIST. https://csrc.nist.gov/pubs/ir/8547/final (final (2026-10-27; the initial public draft of November 2024 is obsoleted). Tables 2 and 4: ECDSA, EdDSA and RSA signatures, finite-field and elliptic-curve DH and MQV, and RSA key establishment are deprecated after 2030 and disallowed after 2035 at every key size — the draft deprecated only the 112-bit level. A composite (hybrid) key establishment stays FIPS 140-validatable while one input comes from an approved scheme. Repeats the federal deadlines of OMB M-26-15: post-quantum key establishment by 2030-12-31 and signatures by 2031-12-31 for high value assets and high impact systems)
23. NIST — Post-Quantum Cryptography Standardization: Evaluation Criteria, Security (Call for Proposals, Section 4.A.5) — NIST. https://csrc.nist.gov/Projects/Post-Quantum-Cryptography/Post-Quantum-Cryptography-Standardization/Evaluation-Criteria/Security-(Evaluation-Criteria) (security categories: AES-128 key search 2^170/MAXDEPTH quantum gates, AES-192 2^233/MAXDEPTH, AES-256 2^298/MAXDEPTH; MAXDEPTH 2^40–2^96)
24. OSV advisory GO-2026-5932 — OSV.dev. https://osv.dev/vulnerability/GO-2026-5932 (modified 2026-11-02T22:15:06.677088389Z)
25. OSV advisory GO-2026-6354 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6354 (modified 2026-09-03T10:10:55.147673102Z)
26. OSV advisory GO-2026-6355 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6355 (modified 2026-09-24T10:41:42.556134596Z)
27. OSV advisory GO-2026-6603 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6603 (modified 2026-10-16T09:55:47.068117441Z)
28. OSV advisory GO-2026-6610 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6610 (modified 2026-10-16T09:56:04.364467528Z)
29. OSV advisory GO-2026-6611 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6611 (modified 2026-10-16T09:55:38.952277866Z)
30. OSV advisory GO-2026-6612 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6612 (modified 2026-10-16T09:55:54.129082194Z)
31. OSV advisory GO-2026-6617 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6617 (modified 2026-10-16T09:55:57.350751224Z)
32. OSV advisory GO-2026-6860 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6860 (modified 2026-10-27T21:30:04.890809062Z)
33. OSV advisory GO-2026-6866 — OSV.dev. https://osv.dev/vulnerability/GO-2026-6866 (modified 2026-10-27T21:45:08.978077289Z)
34. OWASP Application Security Verification Standard — OWASP. https://owasp.org/www-project-application-security-verification-standard/ (living standard — check the project page for the current version)
35. P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997) — SIAM. https://doi.org/10.1137/S0097539795293172 (peer-reviewed article)
36. R. Babbush et al. — Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities: Resource Estimates and Mitigations (arXiv:2603.28846) — arXiv. https://arxiv.org/abs/2603.28846 (preprint (2026-03-30, v2 2026-04-15): 256-bit ECDLP with < 1200 logical qubits and < 90 M Toffoli gates (or < 1450 and < 70 M); < 500,000 physical qubits at 10^-3 error, minutes)
37. S. Jaques, M. Naehrig, M. Roetteler, F. Virdia — Implementing Grover oracles for quantum key search on AES and LowMC (EUROCRYPT 2020; arXiv:1910.01700) — Springer / arXiv. https://arxiv.org/abs/1910.01700 (peer-reviewed article: lower cost estimates for the AES key searches that define the NIST categories)

Приложения

A. Криптографическая инвентаризация

Алгоритм	Параметр	Расположение	Квантовый статус	Классический статус
SHA-2	SHA-256	common/darkside.go:6	Гровер: допустимо по NIST, ниже рекомендаций ECCG/ ANSSI	допустимо
SHA-2	SHA-256	docker/cert.pem (line 1)	Гровер: допустимо по NIST, ниже рекомендаций ECCG/ ANSSI	допустимо
SHA-2	SHA-256	parser/block_header.go:10	Гровер: допустимо по NIST, ниже рекомендаций ECCG/ ANSSI	допустимо
SHA-2	SHA-256	testtools/genblocks/ main.go:28	Гровер: допустимо по NIST, ниже рекомендаций ECCG/ ANSSI	допустимо
X25519MLKEM768	X25519MLKEM768	frontend/rawrequest.go:60	гибрид	допустимо
Crypto library golang.org/x/crypto (Go x/crypto)	v0.55.0	go.mod:53	н/п	допустимо
RSA	2048-bit	common/ generatecerts.go:21	уязвим (Шор)	допустимо
RSA		common/generatecerts.go:8	уязвим (Шор)	допустимо
RSA	2048-bit	docker/cert.pem (line 1) — lightwalletd.testnet.local	уязвим (Шор)	допустимо

B. JSON

qsi.report/1 · SHA-256 9504d578ac265b51de4004dce82ba857ca6f01624df2bbbf459dc504ecb818c6

C. Входные файлы

Файл	Размер	SHA-256	Маскирования
cmd/connstats.go	1196	`47405d57d1b057faf3be41fdcc1227795319cdcdfee56629c630e66953351311`	0
cmd/root.go	20101	`e6152b83ea0eb6273e64456e350279e7be0268da4c136648d4afeaf3e2a1cf9c`	0
cmd/version.go	517	`33979cac0db08986defae5ac62072805d733c30dd303540733b17277616d10cd`	0
common/cache.go	11643	`ba5f9da3c1492a90d48c20c15256a1bf6e354ba8bb1b58cd2fd62d9b4ddcd2a7`	0
common/common.go	25507	`c8f7603b7d32f5b076d1d61bce1be524acbe7ef20bfd35007978e638a04e9d75`	0

common/darkside.go	33254	129a6d62e78a2bfaf78eaf34fc5fd29cadb5d074de1907669c4c63921e7dd30a	0
common/generatecerts.go	2135	010d1a90f0fea3babe111d4e2d463b754c4d574a16ff2840e69b6f6ef92dc19b	0
common/logging/logging.go	1036	5478a895e3bdb5f83bc14e71d715e55d325ceaae9030e6e00a3655460bf1f307	0
common/mempool.go	4431	13def4c96768f0e46aaeec5b248b801c1c267e4f6f4adc4d94ea49f7f9cc5ef2	0
docker/cert.key	97	4d417087d1f5076360d4260961ed5c29a58fa722450b20caf8d68765c54ab3c4	1
docker/cert.pem	1289	8d44580bca050fd5b3a266b8e9c102a88cbdd88c5996c342b4ab8757b94d720c	0
frontend/rawrequest.go	4645	fad7ec20c623c12a517ca838059b1f6f99d76b971c42204a9c168db3cc562efb	0
frontend/rpc_client.go	3780	dd87e4a43595a01119338a5cbc010134af1eae4c90a3857ba8527deeeaec8583	0
frontend/service.go	51588	33abee53b15eece3dadbd2193eadd7c39815b8fedec4c0d589764223fcb78d47	0
go.mod	2431	2c741f2d97ee03e96e8afbeaacc5f3c7ab44cb73af859d3ad4c99930d595c108	0
hash32/hash32.go	1527	961a695822b5bc76ff5decfebc65cfab1fbbb4aada7097177ba9d3d76082c5fa	0
lightwallet-protocol/walletrpc/compact_formats.proto	6490	d8d0c8aaa5ceec7d5dcc188ef25b04011df2ec0254901620fce982fc13aeb32d	0
lightwallet-protocol/walletrpc/service.proto	16054	9352e90977cfd55ead3a0b97048c40d673ad0024d33882ae89e15727fad19138	0
main.go	89	ec16ed2f1a286086fd738c4cbb990cd6790116a39711c6a35fa405ad888a116e	0
parser/block.go	4546	3b21fb1aaf2d4d1737325894d4d2ccbff6013a29257170c67548326884a096a5	0
parser/block_header.go	8236	9fc7957a45629ec9dbadca29fee6ac6527c71a155d123c32bacf743f021a66b2	0
parser/bounds.go	3289	4303340054eaed723ee8da6e0dd6bf431d7cedb4fa9e7bf45691780ad0c7d731	0
parser/fuzz.go	354	d18aa41f9e4f215c8499d4e48add2b3075a481ab746f7f6af4144bdc19994d34	0
parser/internal/bytestring/bytestring.go	6427	cb01a5a03292979ae9d055e1ce37a137fc1c9af4f8a32b8f762040e18fe2719a	0
parser/transaction.go	24187	ff9c519ffdad866ec1ca573f742f2081df7f67c8ace42299f13513c714428265	0
testclient/main.go	4293	3f607912b23700a153a32c0f4ac95f3bb1c353a358ccf5ed2db5979f2f97eb35	0
testtools/genblocks/main.go	4934	6a7eca671d69272de2ba5471acf4d4007fbf1d6289153474360c77ba108048cc	0
testtools/zap/main.go	764	fc24949d4b8271fb936e68aeb6e6240fb258bab038a29a7eef91f615c5607de2	0
walletrpc/compact_formats.pb.go	25356	5ad9198be37bcab74f36ccbc7dca5d891632d03635f65bd70a559b46e74d04ed	0
walletrpc/darkside.pb.go	24975	51100120dc12c58486ad0eff68f564e93d70bbb2096521bef2bb5d59fa8f9b14	0
walletrpc/darkside.proto	7344	8d3582ed9efaaefeb44c2ee432191127339154b677b253350fd8ff85befff5d2	0

walletrpc/darkside_grpc.pb.go	42355	8dd2070e114aeb584628b082dce641654fb7157d4bdac5900e4ab640eb04d740	0
walletrpc/service.pb.go	62312	79749fecb58b41f9c762c374d2e4c4889665c9e450862b2a882061770b00c734	0
walletrpc/service_grpc.pb.go	51351	d5ec3b07634d3b8bbc83bb0981fc370c62b7bd24080b28d44ecc9f8f54cccd43	0